

Contents

Security Audit Review

1

Security Audit Review

```
<div class="eyebrow">Manager-ready review artifact</div>
<h1 class="hero-title">A stronger visual review format for the homelab security architecture</h1>
<p class="hero-text">This enhanced Markdown version keeps the portability of a ``.md`` file while
<div class="badges">
  <span class="badge primary">Status: Needs revision</span>
  <span class="badge ok">Framework: Zero Trust</span>
  <span class="badge">RFC 1918</span>
  <span class="badge">RFC 4193</span>
  <span class="badge warn">FIPS 140-3: Context only</span>
  <span class="badge">Audience: Manager review</span>
</div>

<div class="panel-card">
  <h3>Recommendation</h3>
  <p>Revise and resubmit. The architectural intent is strong, but the document still needs s
</div>

<div class="panel-card">
  <h3>Primary gap</h3>
  <p>The biggest weakness is evidence quality: the source report describes controls confiden
</div>

<div class="panel-card">
  <h3>Mentoring value</h3>
  <p>This draft is a good coaching opportunity because the security instincts are mostly sol
</div>

Scorecard

<div class="score-row">
  <div class="score-head"><span>Architecture & segmentation</span><span class="score-pill">
  <div class="meter"><span style="width:80%"></span></div>
</div>

<div class="score-row">
  <div class="score-head"><span>Standards accuracy</span><span class="score-pill">3 / 5</span>
  <div class="meter"><span style="width:60%"></span></div>
</div>

<div class="score-row">
  <div class="score-head"><span>Evidence & validation</span><span class="score-pill">2 / 5</span>
  <div class="meter"><span style="width:40%"></span></div>
</div>

<div class="score-row">
  <div class="score-head"><span>Professional tone</span><span class="score-pill">2 / 5</span>
  <div class="meter"><span style="width:40%"></span></div>
</div>
```

```
<div class="meter"><span style="width:40%"></span></div>
</div>
```

Strengths already present

```
<div class="review-card">
  <strong>Defense-in-depth is real, not decorative.</strong>
  <p>The original report combines physical separation, VLAN segmentation, alias-driven access.</p>
</div>
<div class="review-card">
  <strong>The writeup correctly recognizes IPv6 as a separate design problem.</strong>
  <p>That is an important strength because RFC 1918 is limited to IPv4 private address space.</p>
</div>
<div class="review-card">
  <strong>Management access is treated as privileged.</strong>
  <p>The report's emphasis on limiting administrative access to a narrower device set shows.</p>
</div>
```

Required revisions

```
<div class="review-card">
  <strong>1. Add evidence for each major security claim.</strong>
  <p>Every important control should have a validation artifact: firewall screenshots, alias details>
    <summary>Reviewer comment area</summary>
    <textarea placeholder="Add your comments for the junior engineer here..."></textarea>
  </details>
</div>
<div class="review-card">
  <strong>2. Tighten standards language.</strong>
  <p>Use RFC 1918 specifically for IPv4 private ranges, use RFC 4193 for IPv6 ULA, and avoid</p>
  <div class="ref-links">
    <a href="https://datatracker.ietf.org/doc/html/rfc1918">RFC 1918</a>
    <a href="https://datatracker.ietf.org/doc/html/rfc4193">RFC 4193</a>
    <a href="https://csrc.nist.gov/projects/cryptographic-module-validation-program/fips-140-2">FIPS 140-2</a>
  </div>
  <details>
    <summary>Reviewer comment area</summary>
    <textarea placeholder="Add your comments for the junior engineer here..."></textarea>
  </details>
</div>
<div class="review-card">
  <strong>3. Replace dramatic language with bounded engineering wording.</strong>
  <p>Terms like "God Mode," "violently drops," or "hijacks" should be rewritten as policy oriented.</p>
  <details>
    <summary>Reviewer comment area</summary>
    <textarea placeholder="Add your comments for the junior engineer here..."></textarea>
  </details>
</div>
```

```

</div>
<div class="review-card">
  <strong>4. Document control limitations.</strong>
  <p>The report should explicitly note what each control does not cover, such as DoH and DoT
  <details>
    <summary>Reviewer comment area</summary>
    <textarea placeholder="Add your comments for the junior engineer here..."></textarea>
  </details>
</div>

```

Reference-backed revision bullets

```

<div class="review-card">
  <strong>RFC 1918 correction</strong>
  <p>Revise internal-block wording so it explicitly says RFC 1918 covers the IPv4 private ra
  <details>
    <summary>Reviewer comment area</summary>
    <textarea placeholder="Add your comments for the junior engineer here..."></textarea>
  </details>
</div>
<div class="review-card">
  <strong>RFC 4193 clarification</strong>
  <p>Revise IPv6 language so it states that Unique Local IPv6 Unicast Addresses are defined
  <details>
    <summary>Reviewer comment area</summary>
    <textarea placeholder="Add your comments for the junior engineer here..."></textarea>
  </details>
</div>
<div class="review-card">
  <strong>FIPS 140-3 caution</strong>
  <p>Revise any compliance-adjacent wording so it clearly states that FIPS 140-3 applies to
  <details>
    <summary>Reviewer comment area</summary>
    <textarea placeholder="Add your comments for the junior engineer here..."></textarea>
  </details>
</div>

```

Coaching notes

```

<div class="review-card">
  <strong>Lead with fact, then effect, then evidence.</strong>
  <p>That structure makes the report read like an engineering review instead of a persuasive
</div>
<div class="review-card">
  <strong>Separate design quality from compliance language.</strong>
  <p>A strong architecture can still be described inaccurately if standards and validation t
</div>
<div class="review-card">

```

Show residual risk.

Mature writeups state what is blocked by default, what is specifically allowlisted, how

This Markdown file is intentionally enhanced with embedded HTML and CSS so it remains a portable document.

Protection rings and coverage gaps

Why this section matters

The current review focuses mostly on network segmentation, traffic filtering, and application-layer enforcement.

Ring model mapping for the current stack

The tools described in the report mostly address network and application-layer enforcement.

Tool / Control	What it addresses	Closest ring or layer relevance	What it does not cover
VLAN segmentation and RFC1918 blocking	East-west isolation and internal reachability policy	Network boundary, above Ring 3	Does not prevent local privilege escalation, kernel compromise, or malicious code already executing on a host.
OPNsense firewall rules and aliases	Layer 3/4 policy enforcement based on interface, IP, and port	Network control plane, outside host CPU rings	Does not harden host kernel attack surface or application runtime integrity on endpoints.
Forced DNS / Port 53 interception	Resolver-path control and DNS policy enforcement	Network / service control, above Ring 3	Does not stop DoH/DoT unless separately controlled, and does not affect kernel-level malware behavior on a host.
Zenarmor NGFW	Layer-7 application awareness, filtering, and reporting	Application/network visibility, roughly adjacent to Ring 3 behavior	Does not operate as kernel exploit mitigation or endpoint EDR on the protected hosts themselves.

Tool / Control	What it addresses	Closest ring or layer relevance	What it does not cover
Suricata IPS	Inline detection and dropping of known-bad traffic at Layer 2 or Layer 3	Network inspection, outside CPU privilege rings	Does not stop post-exploitation privilege escalation after malicious code is already running locally.
GeoIP whitelisting	Reduces unsolicited inbound exposure by geography	Perimeter access reduction, not ring-specific	Does not provide identity assurance, process isolation, kernel integrity, or resistance to VPN/proxy bypass.[cite:157]
Admin device allowlisting	Restricts who can reach management interfaces	Trust boundary near user/admin access, still above Ring 3	Does not prove device health, protect against stolen sessions, or defend the management host kernel if compromised.[cite:157][cite:199]
IPv6 ULA with NAT66 and matching policy	Keeps IPv6 policy aligned with IPv4 segmentation goals	Network architecture, not CPU ring control	Does not itself provide endpoint hardening, kernel self-protection, or runtime exploit mitigation.

Reviewer comment area

```

<strong>What is currently missing at the lower rings</strong>
<p>If Ring 0 is the kernel, then the present report is strongest at the network and application layers.
<ul>
  <li><strong>Ring 0 / kernel protections:</strong> no explicit mention of Secure Boot, kernel hardening, etc.
  <li><strong>Ring 3 / user-space protections:</strong> no explicit mention of application hardening, etc.
  <li><strong>Identity and admin-plane assurance:</strong> no clear mention of MFA, PAM hardening, etc.
  <li><strong>Host visibility:</strong> no host-based logging, auditd-style telemetry, file integrity, etc.
  <li><strong>Container and VM isolation details:</strong> the report names services and publishes details.
</ul>
<details>
  <summary>Reviewer comment area</summary>

```

<textarea placeholder="Add your comments for the junior engineer here..."></textarea>
</details>

Suggested language to add to the review
<p>A concise way to explain the current posture is: "The documented controls primarily reduce the attack surface by..."</p>
</details>

<summary>Reviewer comment area</summary>
<textarea placeholder="Add your comments for the junior engineer here..."></textarea>
</details>

Protection rings and coverage gaps

Why this section matters
<p>The current review focuses mostly on network segmentation, traffic filtering, and application-layer enforcement</p>

Ring model mapping for the current stack
<p>The tools described in the report mostly address network and application-layer enforcement</p>

Tool / Control	What it addresses	Closest ring or layer relevance	What it does not cover
VLAN segmentation and RFC1918 blocking	East-west isolation and internal reachability policy	Network boundary, above Ring 3	Does not prevent local privilege escalation, kernel compromise, or malicious code already executing on a host.[cite:157][cite:199]
OPNsense firewall rules and aliases	Layer 3/4 policy enforcement based on interface, IP, and port	Network control plane, outside host CPU rings	Does not harden host kernel attack surface or application runtime integrity on end-points.[cite:157][cite:207]
Forced DNS / Port 53 interception	Resolver-path control and DNS policy enforcement	Network and service control, above Ring 3	Does not stop DoH or DoT unless separately controlled, and does not affect kernel-level malware behavior on a host.[cite:157][cite:199]

Tool / Control	What it addresses	Closest ring or layer relevance	What it does not cover
Zenarmor NGFW	Layer-7 application awareness, filtering, and reporting	Application and network visibility, roughly adjacent to Ring 3 behavior	Does not operate as kernel exploit mitigation or endpoint EDR on the protected hosts themselves.[cite:201][cite:207]
Suricata IPS	Inline detection and dropping of known-bad traffic at Layer 2 or Layer 3	Network inspection, outside CPU privilege rings	Does not stop post-exploitation privilege escalation after malicious code is already running locally.[cite:200][cite:206]
GeoIP whitelisting	Reduces unsolicited inbound exposure by geography	Perimeter access reduction, not ring-specific	Does not provide identity assurance, process isolation, kernel integrity, or resistance to VPN or proxy bypass.[cite:157]
Admin device allowlisting	Restricts who can reach management interfaces	Trust boundary near user and admin access, still above Ring 3	Does not prove device health, protect against stolen sessions, or defend the management host kernel if compromised.[cite:157][cite:199]
IPv6 ULA with NAT66 and matching policy	Keeps IPv6 policy aligned with IPv4 segmentation goals	Network architecture, not CPU ring control	Does not itself provide endpoint hardening, kernel self-protection, or runtime exploit mitigation.[cite:171][cite:199]

<details>

<summary>Reviewer comment area</summary>

<textarea placeholder="Add your comments for the junior engineer here..."></textarea>
</details>

```

<strong>What is currently missing at the lower rings</strong>
<p>If Ring 0 is the kernel, then the present report is strongest at the network and applicat
<ul>
  <li><strong>Ring 0 and kernel protections:</strong> no explicit mention of Secure Boot, ke
  <li><strong>Ring 3 and user-space protections:</strong> no explicit mention of application
  <li><strong>Identity and admin-plane assurance:</strong> no clear mention of MFA, PAM hard
  <li><strong>Host visibility:</strong> no host-based logging, auditd-style telemetry, file
  <li><strong>Container and VM isolation details:</strong> the report names services and pub
</ul>
<details>
  <summary>Reviewer comment area</summary>
  <textarea placeholder="Add your comments for the junior engineer here..."></textarea>
</details>

<strong>Suggested language to add to the review</strong>
<p>A concise way to explain the current posture is: The documented controls primarily reduce
<details>
  <summary>Reviewer comment area</summary>
  <textarea placeholder="Add your comments for the junior engineer here..."></textarea>
</details>

```